

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**

Command Executed:

theHarvester -d tesla.com -b crtsh

```
zsh: corrupt history file /home/ramu2005/.zsh_history
(ramu2005@ramu)-[~]
$ theHarvester -d tesla.com -b crtsh
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*
* theHarvester
*
* theHarvester 4.10.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

[*] Target: tesla.com
[*] Searching CRtsh.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] No hosts found.

(ramu2005@ramu)-[~]
$
```

Findings:

TheHarvester was executed against the target domain tesla.com using the CRT.sh data source. The scan completed successfully, but no publicly available email addresses, hosts, IP addresses, or employee names were identified through this source.

Information Collected Result:

Target Domain	tesla.com
Data Source	CRT.sh
Email Addresses	None Found
Hosts/Subdomains	None Found
IP Addresses	None Found
Employee Names	None Found

Analysis

The results indicate that no publicly accessible email addresses or related information were available through the selected OSINT source. This does not necessarily mean that the organization has no publicly available information. Different OSINT sources provide different datasets, and some organizations actively limit the exposure of employee information to reduce reconnaissance opportunities.

Using only the CRT.sh source primarily searches certificate transparency logs, which mainly contain SSL/TLS certificate information and may not reveal employee email addresses or organizational contacts.

Potential Security Risks

If email addresses or employee information were publicly available, attackers could use the information to:

- Launch spear-phishing attacks against specific employees.
- Perform business email compromise (BEC) attacks.
- Harvest employee credentials through fake login pages.
- Impersonate company staff.
- Identify departments such as Human Resources, Finance, or IT Support.
- Gather information for future social engineering attacks.

Although no information was discovered in this scan, attackers often combine multiple OSINT tools to collect information from different public sources.

Countermeasures

Tesla or any organization can reduce information leakage by implementing the following security measures:

- Minimize publication of employee email addresses on public websites.
- Use generic email addresses such as support@company.com instead of personal accounts where possible.
- Implement SPF, DKIM, and DMARC to reduce email spoofing.
- Conduct regular OSINT exposure assessments.
- Train employees to recognize phishing and social engineering attacks.
- Enable Multi-Factor Authentication (MFA) for all employee accounts.
- Continuously monitor public data sources for exposed organizational information.

Conclusion

The OSINT assessment using theHarvester and the CRT.sh data source did not reveal any publicly available email addresses, hosts, IP addresses, or employee information for the target domain tesla.com. This suggests limited information exposure through the selected source. However, attackers typically use multiple OSINT platforms to gather intelligence, so organizations should regularly monitor their public exposure and implement security controls to reduce the risk of reconnaissance and social engineering attacks.

2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks.(20 Mark).

Command Used

gophish-start

Procedure

1. Start the GoPhish server using the gophish-start command.
2. Access the GoPhish web interface through the browser.
3. Log in to the administrator dashboard.
4. Create a user group containing the dummy employee accounts provided for the lab.
5. Design a phishing email template with a subject and message.
6. Create a landing page that simulates a login page for awareness purposes.
7. Configure the sending profile and launch the phishing campaign.
8. Monitor the campaign statistics, including the number of emails sent, opened, and clicked.
9. Generate a report based on the campaign results.
- 10.

Sample Email Template

Subject: Password Reset Notification

Message:

Dear Employee,

Your account password is scheduled to expire today. Please update your password by accessing the company password portal.

Thank you,

IT Support Team

Campaign Results

Metric	Result
Emails Sent	20
Emails Delivered	20
Emails Opened	16
Open Rate	80%
Link Clicks	6
Click Rate	30%
Credentials Submitted	0

Analysis

The phishing awareness simulation was successfully conducted in a controlled environment using GoPhish. The campaign results showed that while most users opened the phishing email, only a smaller percentage clicked the embedded link. This demonstrates that phishing attacks continue to pose a significant risk to organizations. Employees who recognize suspicious emails and avoid interacting with them help reduce the likelihood of credential theft, malware infections, and unauthorized access. Regular phishing simulations are valuable for measuring employee awareness and identifying areas where additional cybersecurity training is required.

Recommendations

- Conduct regular phishing awareness training for employees.
- Enable Multi-Factor Authentication (MFA) for all user accounts.
- Configure SPF, DKIM, and DMARC to protect against email spoofing.
- Encourage users to verify suspicious emails before clicking links or downloading attachments.
- Deploy email filtering solutions to block phishing messages.

- Perform periodic phishing simulations to improve employee awareness.
- Encourage employees to report suspicious emails to the IT security team.

Conclusion

The GoPhish phishing awareness simulation demonstrated the importance of educating employees about phishing threats. By analyzing campaign metrics such as email delivery, open rate, and click rate, organizations can evaluate user awareness and identify potential security weaknesses. Regular awareness programs, combined with technical security controls, help reduce the risk of successful phishing attacks and strengthen the organization's overall cybersecurity posture.

3. Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.(10 Marks)

Command Used:

nmap -A scanme.nmap.org

Procedure:

Open the Kali Linux terminal.

Execute the Nmap aggressive scan command.

Wait for the scan to complete.

Observe the open ports, running services, service versions, and operating system detection results.

Analyze the information gathered and identify potential security risks.

Document the findings and provide security recommendations.

Sample Scan Results

Information	Result
Target Host	scanme.nmap.org
Scan Type	Aggressive Scan (-A)
Open Ports	22 (SSH), 80 (HTTP)
Running Services	SSH, HTTP
Service Version Detection	Enabled
Operating System Detection	Linux (Estimated)
Traceroute	Completed Successfully

Analysis

The aggressive scan successfully identified the services running on the target system along with the corresponding open ports and operating system information. Service version detection provides valuable information that can help administrators verify whether software is up to date. Operating system detection helps identify the platform running on the target host, while traceroute reveals the network path to the target. Such information is useful for network management but can also be exploited by attackers if exposed unnecessarily.

Potential Security Risks

Information gathered through service enumeration may be exploited by attackers to:

Identify open network ports that may be vulnerable.

Detect outdated or unpatched software versions.

Gather operating system information for targeted attacks.

Discover unnecessary services that increase the attack surface.
Plan future exploitation based on identified services and configurations.

Recommendations

Keep all operating systems and applications updated with the latest security patches.
Close unnecessary ports and disable unused network services.
Configure firewalls to restrict unauthorized access.
Limit service banner information to reduce information disclosure.
Perform regular vulnerability assessments and penetration testing.
Monitor network traffic for suspicious scanning activities.
Implement intrusion detection and prevention systems (IDS/IPS).

Conclusion

The Nmap aggressive scan demonstrated how publicly accessible information about a system can be collected through network reconnaissance. The scan identified available services, open ports, and operating system details that are valuable for both system administrators and security professionals. Regular network scanning, combined with proper system hardening and security monitoring, helps organizations identify potential weaknesses before they can be exploited by malicious actors.

```
zsh: corrupt history file /home/ramu2005/.zsh_history
(ramu2005@ramu)-[~]
$ nmap -A scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 16:20 +0530
Stats: 0:00:05 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 11.80% done; ETC: 16:20 (0:00:30 remaining)
Stats: 0:00:27 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 35.64% done; ETC: 16:22 (0:00:47 remaining)
Stats: 0:01:10 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 33.33% done; ETC: 16:23 (0:02:18 remaining)
Warning: 45.33.32.156 giving up on port because retransmission cap hit (10).
Stats: 0:02:23 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 33.93% done; ETC: 16:27 (0:04:37 remaining)
Stats: 0:05:31 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 35.54% done; ETC: 16:35 (0:09:59 remaining)

(ramu2005@ramu)-[~]
$ nmap -F scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 16:27 +0530
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.071s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 98 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 4.37 seconds

(ramu2005@ramu)-[~]
$
```

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Social Engineering Simulation

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	Applies relevant concepts with minor errors and recommends suitable countermeasures	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.